

Основы сертификации средств защиты информации по требованиям безопасности информации

Контакты

Алексей Николаевич
Бегаяев

- к.т.н., доцент ИТМО
- Генеральный директор
АО «ИНСЕК-СЗ»
- a.begaev@inseq.ru



Сертификация – это...

- Одна из форм оценки соответствия:
 - государственный контроль;
 - аккредитация;
 - испытания;
 - регистрация;
 - подтверждение соответствия;
 - приемка;
 - ввод в эксплуатацию;
 - иные формы.



ФЗ №184 ст. 2, 5, 7, 20, 21, 23

Система сертификации СЗИ ФСТЭК России

- ? Что и на соответствие чему
сертифицируем
- ? Кто сертифицирует
- ? Каковы основные этапы
сертификации

Контакты

Алексей Николаевич
Бегаев

- к.т.н., доцент ИТМО
- Генеральный директор
АО «ИНСЕК-СЗ»
- a.begaev@inseq.ru



Контакты

Семен Владимирович
Кашин

- Начальник ИЛ
АО «ИНСЕК-СЗ»
- s.kashin@inseq.ru
- +7 981 716 98 46



Что вас ждёт?

- Лекции по порядку, особенностям процесса сертификации ПО, нормативным требованиям
 - Рекомендованы к **очному** посещению
 - Можно и нужно задавать вопросы
 - Можно выбрать финальную тему лекции
- Три практических работы по мерам AppSec
 - Статический анализ
 - Фаззинг-тестирование
 - Проектирование архитектуры
- Зачёт

Что вас ждёт на практике?

- Практика по умолчанию **заочная**
- Практика ведётся **в группах 2-3 человека с потока**
- Вам будут высланы задания на группу, выполнять можно **в любом порядке**
- После выполнения задания нужно оформить **отчёт** и **загрузить на общий диск** – это первый этап «сдача»
- После сдачи требуется **«защитить» работу**, для этого в группе в ТГ будут предоставляться таймслоты, которые можно бронировать
- По умолчанию считается, что «защита» проводится в **онлайн** формате
- **Время защиты общее** для всех учебных групп, **не** всегда будет **привязано** к расписанию
- Можно сдать **очно** в Университете или в офисе АО «ИНСЕК» на наб.р.Смоленки, 14 **по предварительной договорённости**
- Если появляются вопросы – можно писать в группу в ТГ, при необходимости, можем провести очное занятие **по предварительной договорённости**

Из чего складывается оценка

- Каждая работа максимально оценивается в 27 баллов, **суммарно 81**:
 - Критерий правильности выполнения – 9 баллов
 - Критерий оформления отчёта – 6 баллов
 - Критерий защиты – 12 баллов
- В группе в ТГ будут написаны **дедлайны**
 - В случае **несвоевременной** сдачи или защиты **каждый** критерий снижается на 2 балла **за каждую неделю** просрочки
 - Можно уйти в минус
- **Зачёт – 18 баллов**
 - Три вопроса по теории по 6 баллов каждый
- На лекциях можно получить **бонусы** за активность, они суммируются с баллами за практические работы. Да, можно набрать больше 100.
- В БАРС баллы переводится **1к1**, но больше 100 поставить не сможем

- Общие сведения о сертификации СЗИ
 - Основные понятия
 - Требования
 - Системы сертификации СЗИ
 - Нормативная база
- **Общий порядок проведения СИ**
 - Основные виды и схемы СИ
 - Участники СИ
 - Специфика отдельных видов СИ
 - Специфика различных систем сертификации

Сертификация – это...

- Одна из форм оценки соответствия:
 - государственный контроль;
 - аккредитация;
 - испытания;
 - регистрация;
 - подтверждение соответствия;
 - приемка;
 - ввод в эксплуатацию;
 - иные формы.



Система сертификации

- Совокупность правил выполнения работ по сертификации, ее участников и правил функционирования системы сертификации в целом



Система сертификации СЗИ

Федеральный закон
«О техническом регулировании»
№184 от 27.12.2002

Федеральный закон
«О государственной тайне»
№ 5485-1 от 21.07.1993г

ФЗ

Положение «О сертификации средств защиты информации»
(утв. ПП РФ от 26.06.1995 № 608) ред. 2010 г.

ПП РФ

Положение «О системе сертификации
средств защиты информации»
(приказ ФСТЭК России от 03.04.2018 № 55)

Приказ ФСБ РФ от 13 ноября 1999 г. N 564
«СЗИ-ГТ»
Проект Положения 2020 г.?

Приказы
ФСБ
ФСТЭК
МО

Положение «О системе сертификации средств
защиты информации Министерства обороны
Российской Федерации» (Приказ Министра
обороны РФ от 29 сентября 2020 № 488)

Приказ ФСТЭК России от 10.04.2015 № 33
Правила выполнения отдельных работ по
аккредитации

Система сертификации СЗИ

Федеральный закон
"О лицензировании отдельных видов
деятельности" № 99 от 04.05.2011

ГОСТ Р ИСО 9001-2015
Системы менеджмента качества.
Требования

ГОСТ ISO/IEC 17025-2019
Общие требования к компетентности
испытательных и калибровочных лабораторий

ГОСТ Р ИСО/МЭК 27001-2022
Системы менеджмента информационной
безопасности. Требования

Поддерживающие
НПА

Сертифицированные СЗИ?



Приказ ФСТЭК
России №31

Меры защиты информации реализуются посредством **применения** средств защиты информации



Приказ ФСТЭК
России №239

Меры реализуются в том числе посредством применения СЗИ, прошедших в установленном порядке **оценки соответствия**



Приказ ФСТЭК
России №21

Для обеспечения безопасности значимых объектов КИИ должны применяться средства защиты информации, **прошедшие оценку на соответствие** требованиям по безопасности в формах **обязательной сертификации, испытаний или приемки**



Приказ ФСБ
России №378

Использование средств защиты информации, прошедших процедуру **оценки соответствия** требованиям законодательства Российской Федерации

Сертифицированные СЗИ?



Приказ ФСТЭК
России №17

*Для обеспечения защиты
информации
применяются СЗИ,
прошедшие оценку
соответствия в форме
обязательной
сертификации*



Приказ
ФСБ/ФСТЭК
№416/489

*Использование средств
защиты информации ...
сертифицированных ФСБ
России и (или) ФСТЭК
России*

Сертифицированные СЗИ?



ГОСУДАРСТВЕННАЯ
ТАЙНА



ИНФОРМАЦИОННЫЕ
СИСТЕМЫ ОБЩЕГО
ПОЛЬЗОВАНИЯ



ГОСУДАРСТВЕННЫЕ
ИНФОРМАЦИОННЫЕ
СИСТЕМЫ



АВТОМАТИЗИРОВАННЫЕ
СИСТЕМЫ ВОЕННОГО
НАЗНАЧЕНИЯ



СВР? ГРУ? НОВИЧОК???

Сертифицированные СЗИ?

- Самый простой способ для оператора/владельца информационной системы соблюсти требования по обеспечению безопасности
- Контроль соответствия формализованным требованиям
- Контроль отсутствия ошибок и уязвимостей в программном обеспечении



Система сертификации СЗИ ФСТЭК России

- ? Что и на соответствие чему
сертифицируем
- ? Кто сертифицирует
- ? Каковы основные этапы
сертификации

Что сертифицируем?

- Средства противодействия ИТР, а также средства контроля их эффективности
- Средства ТЗИ, включая средства, в которых они реализованы, а также средства контроля их эффективности
- Средства обеспечения безопасности информационных технологий, включая защищенные средства обработки информации



Приказ 55 ФСТЭК России

Кто сертифицирует?



Федеральный орган по сертификации



Органы по сертификации



Испытательные лаборатории



Изготовители средств защиты информации

Кто сертифицирует?



Федеральный орган по сертификации



Органы по сертификации



Испытательные лаборатории



Изготовители средств защиты информации



ФСТЭК России

Кто сертифицирует?



Федеральный орган по сертификации



Органы по сертификации



Испытательные лаборатории



Изготовители средств защиты информации

Кто сертифицирует?



Федеральный орган по сертификации



Органы по сертификации



Испытательные лаборатории



Изготовители средств защиты информации

Кто сертифицирует?



Федеральный орган по сертификации



Органы по сертификации



Испытательные лаборатории



Изготовители средств защиты информации

Кто сертифицирует?



Федеральный орган по сертификации



Органы по сертификации



Испытательные лаборатории



Изготовители средств защиты информации

Кто сертифицирует?



Федеральный орган по сертификации



Органы по сертификации



Испытательные лаборатории



Изготовители средств защиты информации

Кто сертифицирует?



Федеральный орган по сертификации



Органы по сертификации



Испытательные лаборатории



Изготовители средств защиты информации